

QA Report — Tick & Taka (round 3)

Re-verification of the round-2 QA findings, plus a fresh audit of the 42 commits that fixed them

Project	Tick & Taka (monorepo: apps/api, apps/mobile, packages/shared)
Date	7 October 2026
Commit	<code>7e2bfeb</code> on <code>fix/audit-2026-10-06</code> — “chore: keep the audit reports out of Biome and explain the coverage figures”
Baseline	Round 2 at <code>df29d67</code> (QA score 70, 15 findings QA-201...QA-215 plus 5 partly fixed round-1 items); 42 commits since
Auditor role	QA Lead
Mode	Read-only. No source, config, dependency or git state changed. Scratch scripts lived in <code>docs/audit/2026-10-07-r3/_qa_tmp/</code> and were deleted afterwards.
Companion reports	UX_Report.pdf, Code_Quality_Report.pdf (written separately)

Severity scale used in all three reports: **Critical** data loss, security hole, crash or broken core flow · **High** major feature broken or a stated principle clearly violated · **Medium** real problem with a workaround, notable friction or debt · **Low** polish, consistency, minor cleanup. Round-3 findings are numbered from QA-301.

1. Executive summary

87 / 100 overall QA score (round 1: 58 · round 2: 70)

The round-2 fixes hold up. All 15 round-2 findings were re-checked against the code, and the ones a script can reach were reproduced again. 14 are fixed and 1 (the testing gap) is partly fixed. The Critical and the High are both gone. An invalid time zone now gets a 400, a stored bad zone falls back to Asia/Dhaka, and one user whose database won't open is logged and skipped, so the job loop keeps running. A refreshed token keeps working until 60 s after its replacement is first used, and the phone ignores a 401 for a token it has already replaced. CHECK violations now return 400, and a write that keeps failing is set aside where the user can see it. Lint, typecheck and 689 tests pass.

The new code has two Medium problems, both reproduced. **QA-301**: when the server keeps failing on a create, the edits queued behind it get 404 and are dropped. Tapping Retry later recreates the record without those edits. **QA-302**: a budget draft from Tiki stores the whole month's budget lines. If it is saved after another line was changed, that change is silently reverted, and its Undo does the same. Seven Low findings cover narrower edges: an Undo of a replayed bill payment, writes that sit only in memory before the outbox loads, the screen cache being wiped by a key-store hiccup, settings changed by the assistant with no Undo, an export file left behind after sign-out, screens that ignore the time-zone setting, and gaps in the tests. No Critical or High issue remains. Device-only behaviour still couldn't be run (see section 2).

Severity	New in round 3	Previous findings (20)	Count
Critical	0	Fixed	17
High	0	Partially fixed	3
Medium	2	Not fixed	0
Low	7	Regressed	0
Total	9	15 round-2 findings + 5 round-1 items round 2 left partly fixed	

Top 5 to fix first

Medium	QA-301	When the server keeps failing on a create, the edits queued behind it get 404 and are dropped. Retrying the create brings back the old version. Reproduced
Medium	QA-302	Saving an old "set budget" draft, or its Undo, overwrites the whole month and reverts other budget lines. Reproduced
Low	QA-303	Undo of a bill payment whose reply was a replay deletes the expense but leaves the due date a month ahead. Reproduced
Low	QA-304	Writes queued before the outbox has loaded, including the widget hand-over, exist only in memory. A kill in that window loses them.
Low	QA-306	The assistant can turn off App lock or change the default currency, and the change has no Undo. Reproduced

2. Scope & method

What was reviewed

- **Intent:** PRODUCT.md, DESIGN.md, README.md (including “Notes on decisions”), docs/IMPLEMENTATION_PLAN.md and the spec (via `_raw/spec.txt`). The round-2 requirement checklist (Appendix C) was carried over and re-checked in section 4.
- **Re-verification:** each of QA-201...QA-215 and the five round-1 items round 2 left partly fixed (QA-002, 007, 019, 022, 026). This was done by reading the code at `7e2bfeb`, reading the new tests, and re-running a reproduction wherever a script could reach the path.
- **Fresh audit of what changed since round 2** (`git log df29d67..HEAD`, 42 commits, 216 files, +5 273 / -1 283 lines). This covered time-zone validation and the job loop, the refresh grace window, CHECK → 400 and stuck-write handling in the outbox, key failures in encrypted storage, the migration 0004 repair, the legacy-token cutoff, the `/sync/changes` limit and summary, the off-site backup command, the widget hand-over, assistant money drafts and turn recovery, Bangla quick-add parsing, keypad numerals, Undo for bill payments and planner moves, the account-deletion page, and the per-user AI totals.

Commands and evidence

Command	Result	Source
<code>bunx biome check .</code>	523 files, exit 0	<code>_raw/lint.txt</code>
<code>bun run typecheck</code>	shared / api / mobile, exit 0	<code>_raw/typecheck.txt</code>
<code>bun run test</code>	689 pass, 0 fail (shared 247, mobile 233, api 209)	<code>_raw/test.txt</code>
coverage per workspace	api 94.5% lines, shared 96.5%, mobile 93.8% (pure modules only)	<code>_raw/coverage-*.txt</code>
<code>bun audit</code>	5 advisories (2 high, 3 moderate), all transitive (Expo, Tailwind, drizzle-kit), recorded as accepted in the README	<code>_raw/audit.txt</code>
<code>bunx expo export --platform android</code>	bundles (2 837 modules)	<code>_raw/android-export.txt</code>
QA probes (Bun): <code>api-probe.ts</code> , <code>pay-undo.ts</code> , <code>settings-probe.ts</code> , <code>auth-sweep.ts</code> , <code>mig-schema.ts</code> , <code>qa-probe.ts</code> (+ the same probe against <code>df29d67</code> 's parser, extracted with <code>git archive</code>)	These import the project's own code: <code>createTestContext</code> (in-memory SQLite, injected clock), the fake AI, the real mobile <code>OutboxQueue</code> and <code>undoPayRequests</code> , and the real drizzle migrations. Upload and backup folders were pointed into <code>_qa_tmp/</code> . Output is in Appendix B.	<code>_qa_tmp/</code> (deleted)

What could not be verified (marked Unverified where it matters)

- **Anything that needs a device.** Sign-in is Google-only, and the only emulator image has no Play services. So none of the following ran on a phone: the app lock, notifications and quiet hours, the widget and its headless task (QA-304 timing), Android Keystore and `expo-secure-`

store failure modes (QA-305), how Hermes' Intl handles time zones the server accepts (for example "+06:00"), the keypad's Bangla digits (19bd4f1), the snackbar's accessibility timeout, AsyncStorage size limits, and recovery after a dropped assistant stream. These were judged by reading the code.

- **Network timing.** The refresh grace window was checked with an injected clock (Appendix B), not on a real mobile network. QA-303 needs a lost reply. It was simulated by sending the same pay twice, which is exactly what the outbox does after a timeout.
- **pm2, Nginx and BACKUP_OFFSITE_CMD** were not run. The off-site copy was judged from jobs/offsite.ts and its test.
- **AI.** No real OpenAI calls were made. Tool calls were scripted through the project's FakeAi , so whether a real model would actually choose a given call (for example update_settings {appLock:false}) was not tested.
- The screenshots in docs/screenshots predate every fix and were not used as evidence.

3. Previous findings status

Line references are at 7e2bfeb. “Re-run” means a probe in this round reproduced the round-2 scenario and now gets the expected result (Appendix B).

ID	Sev.	Round-2 title (short)	Status	Evidence at 7e2bfeb
QA-201	C	Bad time zone or unopenable DB crashes the job runner	Fixed	Zones are validated with <code>isTimeZone</code> (<code>packages/shared/src/schemas/settings.ts:L25</code> , <code>dates.ts:L47-L61</code>). <code>readSettings</code> falls back key by key (<code>modules/settings/service.ts:L12-L24</code>). Each user's jobs run in a try/catch (<code>jobs/scheduler.ts:L83-L95</code>), <code>tick()</code> catches its own rejection (L108-L116), and <code>installCrashLogging</code> logs any unhandled rejection (<code>lib/log.ts:L44-L52</code> , <code>index.ts:L11</code>). Migration 0004 repairs bad rows before the rebuild (<code>drizzle/0004_constraints.sql:L8-L54</code>). Re-run: <code>PATCH {timeZone:"Dhaka"}</code> → 400, <code>/today</code> → 200, a throwing lease → <code>runHourlyJobs</code> resolves. A schema diff found no column that became NOT NULL. Residual: <code>update_settings</code> still has no allow-list or Undo (QA-306).
QA-202	H	Refresh signs the user out when a request still carries the old token	Fixed	The server no longer revokes on refresh (<code>auth/routes.ts:L64-L70</code>). The old session is shortened to 60 s after the new token's first use (<code>db/sessions.ts:L40-L44</code> , L107-L112). The phone sets the token in memory before writing <code>SecureStore</code> (<code>lib/session-manager.ts:L66-L76</code>), ignores a 401 for a replaced token, and waits on a refresh in flight (L95-L105, <code>http.ts:L192-L200</code>). Tested in <code>session-manager.test.ts:L79-L127</code> . Re-run: old token 200 at 59 s after the new one is used, 401 at 61 s.
QA-203	M	Edit after a bulk move dropped on replay	Fixed	<code>rescue-overdue</code> replies with the moved rows, and <code>stampedRows</code> walks lists (<code>outbox-policy.ts:L113-L125</code>). Covered by <code>apps/api/test/bulk-then-edit.test.ts</code> and an outbox test.
QA-204	M	A write that keeps failing blocks the queue invisibly	Fixed	CHECK/NOT NULL → 400 <code>invalid_data</code> (<code>middleware/error-handler.ts:L27-L37</code>). After 8 non-503 5xx a write is parked (<code>outbox-policy.ts:L86-L96</code> , <code>outbox-queue.ts:L247-L254</code>). The online “waiting” line and the stuck card with Retry/Discard are in <code>components/ui/sync-status.tsx:L27-L59</code> , L81. The new parking rule has its own gap: QA-301.

ID	Sev.	Round-2 title (short)	Status	Evidence at 7e2bfeb
QA-205	L	Widget queue uncounted, plain, lossy hand-over	Fixed	Logs are removed by id after re-reading (<code>widget-cache.ts:L155-L163</code> , <code>widget-pending.ts</code>). The sign-out warning counts widget writes (<code>confirm-sign-out.ts:L46</code>). Plain storage is a documented exception (<code>secure-storage.ts:L127-L132</code>). Residual timing gap: QA-304.
QA-206	L	Decrypt failure deletes the outbox; silent plain fallback	Fixed	<code>KeyUnavailableError</code> is now separate from a wrong key. A wrong-key value is moved to <code>.unreadable</code> , not deleted, and the plain fallback is reported (<code>encrypted-storage.ts:L57-L79</code> , <code>secure-storage.ts:L134-L143</code>). The outbox keeps an unreadable saved queue untouched (<code>outbox-queue.ts:L142-L150</code>). Residual for the screen cache: QA-305.
QA-207	L	Cold-start queue idle until a network/AppState event	Fixed	<code>load()</code> kicks the outbox once the token is read (<code>session-manager.ts:L56-L57</code>). Tested (<code>session-manager.test.ts:L60</code>).
QA-208	M	Budgets and money fields bypass drafts; <code>set_budget</code> has no Undo	Fixed	<code>movesMoney</code> covers every <code>*Minor</code> field and <code>budgetType</code> (<code>assistant/tools.ts:L22-L30</code>). <code>set_budget</code> drafts, keeps rollover and has an Undo (<code>assistant/actions.ts:L149-L201</code>). Tested in <code>assistant-money-drafts.test.ts</code> . New issue with the stored snapshot: QA-302.
QA-209	M	Old pay draft pays the next period too	Fixed	The draft carries <code>dueAt: bill.nextDueAt</code> (<code>actions.ts:L67-L74</code>), and a late Save says "already done" (<code>money-drafts.ts:L59-L66</code>).
QA-210	L	Phone's own writes listed as Tiki's after a dropped turn	Fixed	Ids the outbox wrote within the last hour are excluded (<code>lib/phone-writes.ts</code> , <code>recover-turn.ts:L64-L65</code>). Narrow residual, not re-raised: expenses the widget posts directly, and writes from before an app restart, aren't in that in-memory set.
QA-211	M	New failure paths untested	Partially fixed	Now tested: the refresh race (<code>session-manager.test.ts</code>), job isolation (<code>jobs.test.ts</code>), zone validation (<code>time-zone.test.ts</code>), the migration on legacy rows (<code>migrations.test.ts:L133</code>) and bulk-then-edit. Still untested: the sync pull (<code>lib/sync-changes.ts</code>) and the other glue listed in QA-309.
QA-212	L	Raw phone clock in focus; offset not persisted	Fixed	Focus uses <code>toServerTime / editTime</code> (<code>focus-screen.tsx:L59, L79, L102</code>). The offset is saved and restored (<code>server-clock.ts:L20-L50</code> , <code>_layout.tsx</code>). The server treats a tap up to 30 min in the future as now (<code>time-entries/service.ts:L18-L33</code>).

ID	Sev.	Round-2 title (short)	Status	Evidence at 7e2bfeb
QA-213	L	Foreign spending moves taka safe-to-spend; foreign bill "Paid" without rate	Fixed	<code>applyOptimistic</code> skips non-default currencies (<code>lib/outbox.ts:L98-L105</code> , <code>optimistic-spend.ts</code>). Today opens the sheet when <code>payNeedsRate</code> is true (<code>today/pay-needs-rate.ts</code>).
QA-214	L	Multi-amount line, trailing danda, "2x150"	Fixed	Re-run, before → after: "৳ ২০, সিন্ধুরা ১০" ৳10 high → ৳30 low; "৳ ২০।" task → ৳20; "lunch 2x150" task → ৳300 (<code>quick-add.ts</code> <code>parseMoneyList</code> , <code>TRAILING_PUNCTUATION_RE</code> ; <code>calculator.ts:L125-L128</code>).
QA-215	L	Bangla digits dropped in count/minute fields	Fixed	<code>parseTypedInteger</code> (<code>digits.ts:L22-L25</code>) is used in <code>habit-sheet.tsx:L37</code> and <code>routine-runner.tsx:L99</code> . A grep found no other typed <code>Number (...)</code> ; the remaining ones read picker values.
QA-002	C (r1)	Offline create then edit loses the edit	Fixed	The remaining bulk-move case was closed by QA-203.
QA-007	H (r1)	Replayed "Paid" advances twice	Fixed	The remaining cases were closed by QA-209 and QA-213. A new edge in the added Undo is QA-303.
QA-019	M (r1)	Assistant saves money without confirmation	Fixed	Closed by QA-208. Settings are outside the money rule; see QA-306.
QA-022	M (r1)	Reminder gaps	Partially fixed	Unchanged since round 2: reminders are rescheduled only when the app opens (<code>use-notification-scheduler.ts</code>), with an 8-day lookahead and no background task (no <code>expo-task-manager</code> in the app). Low, not re-raised.
QA-026	L (r1)	Coverage numbers unreliable	Partially fixed	Documented in README ("Coverage", L388). The api and mobile runs still show <code>shared/src/dates.ts</code> at 5.99% and 0.00% lines (<code>_raw/coverage-api.txt:L110</code> , <code>coverage-mobile.txt</code>). Accepted as a tooling limit.

Tally: 17 fixed, 3 partially fixed, 0 not fixed, 0 regressed. Of the 15 round-2 findings, 14 are fixed and 1 is partly fixed.

4. Requirements traceability

The requirements are those from round 2 (spec build checklist and technical rules, PRODUCT.md and the round-1 fix contract). Status: **Implemented** **Partial** **Missing** **Broken**. “Implemented” means the code path exists and is tested or was read end to end. It does not mean it was run on a device.

Requirement	Implementation	Status	Notes
Sign-in, sessions, per-user SQLite + migrations	auth/routes.ts, middleware/auth.ts, db/sessions.ts, db/client.ts, drizzle/0004	Implemented	Sliding sessions with a 60 s grace for the refreshed-away token. Legacy tokens without a jti are honoured until 7 Nov 2026 (auth.ts:L21). 0004 repairs bad rows first.
Auth on every protected route	app.ts, requireAuth	Implemented	Re-run: all 141 routes swept without a token. Only /health, /, /privacy, /terms and POST /auth/google (400) don't answer 401.
Offline cache + queued writes in order	outbox-*.ts, query-client.ts, secure-storage.ts	Partial	The core works and stuck writes are visible. Gaps: dependants of a parked write (QA-301), memory-only writes before load (QA-304), screen cache wiped on a key hiccup (QA-305).
Conflicts: last write wins on updated_at	crud.ts:L83-L88, outbox-policy.ts:L113-L148	Implemented	Bulk moves are followed, and the clock offset persists.
GET /sync/changes	sync/routes.ts, sync-changes.ts	Implemented	Re-run: limit caps each table and sets more . summary=true returns counts only. limit=5000 → 400. The pull uses the summary.
Quick-add (Bangla + English)	shared/quick-add.ts, digits.ts, calculator.ts	Implemented	Multi-item lines sum at low confidence. A trailing danda or full stop is stripped. Reproduced in Appendix B.
Tasks, subtasks, repeat, undo; planner moves	tasks/service.ts, bulk-move.ts, plan/use-move-task.ts	Implemented	New Undo for planner moves sends edit times that the outbox lifts.
Recurrence in plain words	shared/recurrence.ts	Implemented	—
Overdue rescue, does-my-day-fit, evening, someday	tasks/bulk-move.ts	Implemented	Replies carry the stamped rows.
Focus timer / time tracking	time-entries/service.ts, focus-screen.tsx	Implemented	Uses server time; future taps are clamped.
Habits, streaks, freezes; routines	habits/*, routines/*	Implemented	Bangla digits accepted. The default habit date ignores the zone setting (QA-308).
Accounts, computed balances, balance check	accounts/service.ts	Implemented	—

Requirement	Implementation	Status	Notes
Budgets: buckets, rollover; safe to spend	budgets/service.ts, shared/finance.ts	Implemented	The assistant's budget drafts are stale-prone (QA-302).
Bills, "Paid" creates transaction, Undo	recurring/service.ts, money/recurring-pay.ts	Partial	Pay is idempotent. Undo after a replayed pay leaves the due date moved (QA-303).
Goals, debts, keypad, events, shopping	goals/, debts/, calculator.ts, events/, shopping/	Implemented	The keypad shows Bangla digits when Numbers is Bangla Unverified .
SMS auto-capture	—	Missing	Dropped by a recorded decision.
Widget, launcher shortcuts	features/widget, use-app-shortcuts.ts	Implemented Unverified	Undo on the widget, and taps counted at sign-out. Hand-over timing: QA-304.
Local notifications, quiet hours, bill reminder	features/notifications/*	Partial	Rescheduled only when the app opens (QA-022 residual).
Nightly backup (keep 14), off-site copy, JSON export	jobs/backup.ts, jobs/offsite.ts, scheduler.ts, sync/routes.ts	Implemented	Backups are checked, isolated per user and copied off-site by an optional command. The phone keeps the export file afterwards (QA-307).
Fingerprint lock after 5 min; privacy mode	app-lock.tsx, lock-decision.ts	Implemented Unverified	The assistant can turn it off without Undo (QA-306).
Data at rest protected	encrypted-storage.ts, secure-storage.ts	Implemented	Key failures no longer delete data. Exceptions: the widget store (documented) and the export file (QA-307).
Login 5 / 15 min; API on 127.0.0.1	auth/routes.ts:L34, env.ts	Implemented	—
AI with graceful fallback; cost cap	ai/usage.ts, modules/ai/*	Implemented	Per-user totals are kept in users.db and recounted nightly.
AI never saves money without confirmation	assistant/tools.ts, actions.ts	Implemented	Settings aren't covered (QA-306).
Account deletion	DELETE /auth/account, settings/delete-account.tsx	Implemented	Its own page, with an export first and a typed DELETE to confirm.

5. Findings

Grouped by category, with the categories ordered by their worst finding. **Reproduced** means a Bun script calling the project's own code produced the output shown. The full output is in Appendix B.

5.1 Offline sync & local storage

QA-301 · When the server keeps failing on a create, the edits queued behind it get 404 and are dropped, and Retry brings back the old version

Medium

Category: Offline / data loss Effort: M

Reproduced

Where: `apps/mobile/src/lib/outbox-queue.ts:L247-L254` (park after `STUCK_AFTER`), `:L90-L98` (`retryStuck` appends to the end), `:L284-L292`. `outbox-policy.ts:L70-L79` (`404 → reject`), `:L86-L96`. `components/ui/sync-status.tsx:L27-L59` (one Retry per entry). `apps/api/src/db/user-registry.ts:L186-L192` (a database that won't open is a plain 500).

What's wrong: Parking a write that failed 8 times lets the writes behind it go, but some of those depend on it. A PATCH or DELETE of a record whose create is parked gets 404. `classifyFailure` calls that final, so the edit is dropped with a toast. When the user later taps Retry on the parked create, the record is created as it was first typed. The same happens to a transaction whose new account is parked (`400 invalid_reference`). If every request 500s for about two minutes (a user DB that won't open, a full disk, a bad deploy that still answers), each queued write is parked in turn. The user then has to tap Retry once per write, and each retry goes to the back of the queue. Retrying an edit before its create drops the edit too.

```
// Real OutboxQueue; the API answers POST /tasks with 500 eight times, then works.
enqueue POST /tasks          {id, title: "Call bank"}
enqueue PATCH /tasks/{id}    {title: "Call bank about card", updatedAt}
STUCK-CREATE: stuck POST /tasks | rejected PATCH tasks | stuck=["POST"]
                | after Retry: 200 title="Call bank" | queue size 0
```

Why it matters: The edit is lost for good. It was only ever on the phone, and the phone has already said it couldn't save it, which is a confusing message for an edit to something the user can still see. This happens in exactly the situation parking was built for: a server bug or outage.

Recommendation: When parking, also park every queued entry that names the same record id, in its path or as its body `id`, plus anything whose body references it. Retry and Discard should then act on the whole group, in order. Add "Retry all", which re-queues the parked entries in their original order. On the server, return 503 (not 500) when a user's database can't be opened, so the phone waits instead of parking.

QA-304 · Writes queued before the outbox has loaded, including the widget hand-over, exist only in memory

Low

Category: Offline / start-up Effort: S

Unverified on device

Where: `apps/mobile/src/lib/outbox-queue.ts:L169-L179` (`enqueue`), `:L320-L322` (`persist` is a no-op until loaded), `:L142-L150` (unreadable saved queue: stays unloaded).

features/widget/use-widget-sync.tsx:L43-L54 . app/_layout.tsx:L80-L84 (startOutbox() fire-and-forget).

What's wrong: `persist()` returns early until the saved queue has been read, so it can't overwrite it, and writes queued before then live only in memory. On start-up, `useWidgetSync` reads the widget's offline list, enqueues each log, and then trims those logs from the widget's own storage. It doesn't wait for the outbox to load or for its save to finish. While the storage key can't be read, the outbox stays unloaded indefinitely. In that state every new expense, and every widget log handed over, exists only in memory, even though the screen says it's saved on the phone.

```
// use-widget-sync.tsx L45-L48
const pending = await readPendingLogs();
for (const log of pending)
  send({ method: "POST", path: "/transactions", body: { ...log, type: "expense" } });
if (pending.length) await removePendingLogs(pending); // no await on the outbox's own
save
```

Why it matters: If the app is killed or crashes in that window, those expenses are gone. Normally the window is a few hundred milliseconds. With a Keystore that won't unlock, it lasts as long as the app is open.

Recommendation: In `useWidgetSync`, `await startOutbox()`, skip the hand-over while `outbox.savedUnreadable`, and `await outbox.flushed()` before `removePendingLogs`. While the saved queue is unreadable, write new entries to a separate side key (for example `tt.outbox.pending`) that `load()` merges. Say “not saved yet” in the status line.

QA-305 · A storage-key hiccup at start-up still deletes the encrypted screen cache

Low

Category: Storage / offline Effort: S

Unverified on device

Where: `apps/mobile/src/lib/query-client.ts:L74-L89` (`persist` over `secureStorage`). `encrypted-storage.ts:L60-L63` (`rethrows KeyUnavailableError`). `TanStack persistQueryClientRestore` (`node_modules/@tanstack/query-persist-client-core/build/modern/persist.js`), which calls `persist.removeClient()` whenever `restoreClient` throws.

What's wrong: The round-2 fix keeps sealed values when the key can't be read, and the outbox honours that. The query cache doesn't: `restoreClient` rethrows, and `TanStack` responds by discarding the persisted cache. So if the key can't be read once on a cold start, the offline copy of balances, tasks and today is deleted. This contradicts the module's own promise: “the sealed value stays as it is, to be read on a later try”.

Why it matters: Opening the app offline after such a start shows empty screens until it reaches the server. No server data is lost.

Recommendation: Wrap `restoreClient` so it catches `KeyUnavailableError` and returns `undefined`, which means no cache rather than a broken one. Then retry the restore on the next foreground. Add a unit test with a cipher that throws `KeyUnavailableError`.

QA-307 · The full JSON export is left in the app's cache folder after sign-out and account deletion

Low

Category: Privacy / data at rest Effort: S

Where: `apps/mobile/src/features/settings/use-export-data.ts:L14-L22` . `lib/user-data.ts:L21-L33` (`clearUserData` clears `AsyncStorage` and the caches, not files).

What's wrong: The export (every table, notes and amounts included) is written as plain JSON to `Paths.cache/tick-taka-export-YYYY-MM-DD.json` so it can be shared, and it is never deleted. The new delete-account page suggests exporting right before deleting. `clearUserData`, which promises to leave “nothing of the signed-out user on the phone”, doesn't touch that file. The whole export is also parsed into memory and re-stringified (`send("GET", "/export")`), even though the server streams it to avoid exactly that.

Why it matters: A full copy of the user's money history stays on the phone, unencrypted, after they sign out or delete the account. Android's cache folder is app-private, so the risk is limited to device dumps and rooted phones.

Recommendation: Delete the file once `shareAsync` resolves, and sweep `tick-taka-export-*.json` in `clearUserData`. Download straight to a file (`File.downloadFileAsync` with the auth header) instead of parsing the JSON.

5.2 AI assistant

QA-302 · Saving an old “set budget” draft, or its Undo, overwrites the whole month and reverts other budget lines

Medium

Category: AI / money correctness Effort: S-M

Reproduced

Where: `apps/api/src/modules/ai/assistant/actions.ts:L160-L193` (snapshot of all lines → draft body and undo). `modules/budgets/service.ts:L249-L283` (`putBudgets`: “Replaces a month's budgets ... others in the month are removed”). `apps/mobile/src/features/assistant/use-assistant.ts:L220-L236` (drafts stay pending in the saved chat, with no expiry).

What's wrong: To change one line, `set_budget` reads every line of the month and puts the full list into the draft body (`PUT /budgets {month, budgets:[...all...]}`). The Undo is the full list from before. A draft can sit in the chat for days. If the user changes any other budget in that month first (in the Budgets screen, or with another draft), Save writes back the old values for every other line, and deletes lines added in the meantime. The card only says “Set the Food budget for 2026-10 · ₹8,000”. The same happens to the Undo of a saved, or non-draft, `set_budget`.

```
Fun = ₹2,000 when the draft "Food 8000" is made
user sets Fun = ₹3,000 in Budgets an hour later
Save on the old draft: PUT /budgets → 200 → Food=800000, Fun=200000 (Fun silently
back to ₹2,000)
```

Why it matters: Budgets drive the daily safe-to-spend number, which is the product's core number. A confirmed one-line change silently undoes another one, with nothing on screen to show it.

Recommendation: Give the API a one-line upsert, for example `PUT`

`/budgets/:month/:categoryId {limitMinor, rollover}` and `DELETE` for removal. Make the draft and its Undo touch only that line, with Undo restoring the line's previous value or deleting it. Until then, re-read the month at Save and re-apply only the changed line on the phone.

QA-306 · The assistant's `update_settings` applies any setting with no Undo, including turning off App lock

Low

Category: AI / safety Effort: S

Reproduced

Where: `apps/api/src/modules/ai/assistant/actions.ts:L216-L221` . Tool description at `tools.ts:L107` . The runner's own contract ("Every change ... is recorded with a way to undo it") is at `tools.ts:L147-L150` .

What's wrong: `update_settings` forwards whatever fields the model sends to `PATCH /settings` . There's no allow-list and no draft, and the action is recorded without an `undo` . Round 2 recommended both. Zone validation now stops the crash, but the model can still switch `appLock` off, change `lockAfterMinutes` , turn AI features off (which also removes the assistant), or change `defaultCurrency` , which decides which accounts count toward safe-to-spend. A mis-heard voice note or text injected into a note the assistant reads is enough.

```
update_settings {defaultCurrency:"USD", appLock:false} with draftMoney:true
→ drafts 0, actions [{"summary":"Changed settings: defaultCurrency, appLock"}]    (no
undo)
→ settings now: defaultCurrency=USD appLock=false
```

Why it matters: A security setting changes without a tap. There's no Undo, and no screen says what the value used to be.

Recommendation: Allow-list the low-risk keys (theme, dailyTaskGoal, focus, quietHours, vacationMode, weeklyFocus...). Make `appLock` , `lockAfterMinutes` , `ai` , `defaultCurrency` , `defaultAccountId` and `timeZone` drafts, or refuse them. Record an Undo with the previous values, the same way `update` does.

5.3 Money & time

QA-303 · Undo of a bill payment whose reply was a replay deletes the expense but leaves the due date a month ahead

Low

Category: Money / Undo Effort: S

Reproduced

Where: `apps/api/src/modules/recurring/service.ts:L100-L109` (a replay returns `previousDueAt: null`). `apps/mobile/src/features/money/recurring-pay.ts:L14-L31, L41-L59` .

What's wrong: The new Undo for "Paid" uses the reply's `previousDueAt` to move the due date back. When the first reply is lost (a timeout on a slow network after the server has committed), the outbox resends the same `transactionId` . The server treats that as a replay and answers with the logged transaction but `previousDueAt: null` . `undoPayRequests` then only deletes the expense.

```
first pay → previousDueAt 2026-10-05 (reply lost) | replay → previousDueAt null, same transaction
undo requests: DELETE transactions
after Undo: nextDueAt 2026-11-05 | expenses 0 (October's bill now looks paid)
```

Why it matters: After Undo the bill disappears from Today until next month, so the user may never pay October's bill. The trigger is narrow: a lost reply followed by Undo while the snackbar is still up.

Recommendation: On a replay, return the due date the logged payment moved from. It can be stored on the transaction (for example `recurring_due_at`) or derived by stepping the rule back once from the current `nextDueAt`. Alternatively, add `POST /recurring/:id/unpay {transactionId}` that does both steps on the server in one transaction.

QA-308 · Ten client spots work out “today” or “this month” in Asia/Dhaka, whatever the time-zone setting says

Low Category: Time zones Effort: S

Where: `toLocaleDate(Date.now())` / `toLocaleMonth(Date.now())` with no zone in `features/habits/queries.ts:L5`, `money/budgets-screen.tsx:L32`, `app/budget-edit.tsx:L9`, `review/monthly-review.tsx:L26`, `review/payday-plan.tsx:L26`, `review/review-home.tsx:L77`, `money/events-screen.tsx:L31`, `money/goal-sheet.tsx:L114`, `app/pick-top-three.tsx:L7`, `app/plan/day.tsx:L7`.

What's wrong: The server and most screens use `userTime(settings).timeZone`. These ten use the shared default instead. For a user whose zone isn't Asia/Dhaka, habits are logged against the Dhaka date, and the budget editor, monthly review and payday plan open on the wrong month for up to 18 hours around midnight on the first. The “Sunday” review prompt is also off.

Why it matters: It only affects users outside Bangladesh, but the app now validates and accepts any zone, and the server already respects it.

Recommendation: Use a `useToday()` or `useThisMonth()` hook built on `userTime`. Add a lint rule (Biome `noRestrictedImports` -style, or a grep in CI) that flags `toLocaleDate(Date.now())` without a zone.

5.4 Testing

QA-309 · The glue around the new fixes is untested, and so are the three reproduced bugs

Low Category: Testing Effort: M

Where: No tests for `apps/mobile/src/lib/sync-changes.ts` (pull, cursor, wait-for-outbox), `lib/outbox.ts` (`describe: captive-portal` and `401` mapping; `applyOptimistic`), `features/widget/use-widget-sync.tsx` (hand-over order), `features/assistant/recover-turn.ts` (only the pure `recoveredActions` is tested), `lib/secure-storage.ts` (`storageKey` retry), or the persister restore path. `outbox-queue.test.ts:L293-L332` tests parking with a single entry only.

`recurring-pay.test.ts` doesn't cover a replay reply. `assistant-money-drafts.test.ts:L52-L96` doesn't change another line between draft and Save.

Quality of what exists: Good. 689 tests, up from 568, with exact-value assertions, an injectable clock and real routes. The mobile pure modules sit at 93.8% of lines. Every round-2 P0 case in section 8 of that report now has a test. No flaky patterns were seen. Each of QA-301, 302 and 303 sits on a path the suite never reaches with more than one write or more than one actor.

Recommendation: Add the cases in section 8.

6. Strengths (keep these)

- **Fixes come with the test that proves them.** Nearly every fix commit since round 2 names its finding and adds a test that fails without it: `jobs.test.ts` (bad lease, bad zone, a rejected tick), `time-zone.test.ts`, `session-manager.test.ts` (seven race cases), `bulk-then-edit.test.ts`, migration repairs, `constraints.test.ts` and the stuck-write tests.
- **Failure isolation on the server.** A user whose data can't be read is logged under an HMAC tag and skipped. An unhandled rejection is logged instead of crashing the process. Accounts deleted mid-run are skipped. The off-site command can't throw into the loop.
- **A careful session lifecycle.** The token changes in memory before the slow writes. A 401 is attributed to the token that was actually sent, and the server's grace window only ever shortens. The legacy-token cutoff has a date and a reason in the code.
- **The outbox is honest with the user.** Online stalls and stuck writes show with Retry and Discard. The sign-out and delete-account flows count unsynced writes, widget taps included. Undo now exists for Paid, Received, Skip and planner moves, and it goes through the same queue.
- **Defensive migrations.** 0004 brings every row to the nearest value the new CHECKs accept, before rebuilding. It is tested on a populated legacy database, and broken foreign keys are logged as JSON.
- **Bangla input handled at the root** and checked by table tests. Multi-item lines are summed at low confidence, so the AI or the preview checks them.
- **Clean gates:** Biome, typecheck and 689 tests all pass, CI runs them on every push, and the README explains the coverage limits honestly.

7. Action plan

Order	ID	Title	Severity	Effort
1	QA-301	Park dependent writes with the parked one; “Retry all” in order; 503 for a DB that won't open	Medium	M
2	QA-302	One-line budget upsert for assistant drafts and their Undo	Medium	S-M
3	QA-309	Tests for the cases in section 8 (P1 first)	Low	M
4	QA-303	Return the original due date on a replayed pay (or a server-side unpay)	Low	S
5	QA-304	Await the outbox before the widget hand-over; persist writes queued while unloaded	Low	S
6	QA-306	Allow-list, drafts and Undo for <code>update_settings</code>	Low	S
7	QA-305	Don't let a key hiccup discard the screen cache	Low	S
8	QA-307	Delete the export file after sharing and on sign-out	Low	S
9	QA-308	Zone-aware today/month hooks in the ten spots	Low	S

8. Recommended test plan

P1 covers the Medium findings, P2 the Low ones and remaining hardening. "API" means `createTestContext`. "Integration" means the real `OutboxQueue` with `send` wired to the in-memory API, as in this audit's probes.

Pri	Type	Covers	Given / When / Then
P1	Integration	QA-301	Given a queued POST /tasks that gets 500 eight times and a queued PATCH of the same task, when the queue runs, then both are parked together, and Retry sends them in order and ends with the edited title.
P1	Unit (mobile)	QA-301	Given three parked writes A, B, C, when "Retry all" is tapped, then they are re-queued A, B, C ahead of nothing else and none is rejected.
P1	API	QA-301	Given a user whose database fails to open, when any authenticated request arrives, then 503 (not 500), and the phone policy classifies it as retry, never stuck.
P1	API (fake AI)	QA-302	Given a set_budget draft for Food, when Fun is changed and the draft is then saved, then Food has the new limit and Fun keeps the changed one. When the draft's Undo is sent, then only Food changes back.
P2	API + unit	QA-303	Given a pay sent twice with the same transactionId, when <code>undoPayRequests</code> (second reply) is sent, then the expense is gone and <code>nextDueAt</code> is back on the original date.
P2	Unit (mobile)	QA-304	Given an outbox whose <code>load</code> hasn't resolved and two pending widget logs, when the hand-over runs, then the widget list is not trimmed until the outbox's save that contains both has resolved.
P2	Unit (mobile)	QA-305	Given a cipher whose <code>decrypt</code> throws <code>KeyUnavailableError</code> , when the persister restores, then <code>removeClient</code> is not called and the sealed cache is still in storage.
P2	API (fake AI)	QA-306	Given <code>update_settings {appLock:false}</code> , then a draft (or a refusal), and <code>appLock</code> unchanged. Given <code>{theme:"dark"}</code> , then applied with an Undo that restores the old theme.
P2	Unit (mobile)	sync pull	Given a stored cursor and a non-empty outbox, when <code>pullChanges</code> runs, then it waits for <code>sending === 0</code> and doesn't advance the cursor on timeout. Given a summary reply, then the cursor equals <code>serverTime</code> and only the mapped paths refresh.
P2	Unit (mobile)	outbox glue	Given an <code>ApiError</code> with code <code>http_error</code> and status 502, then <code>describe</code> says unreachable. With 401, then status 401. Given a USD-account expense, then <code>applyOptimistic</code> leaves <code>leftToday</code> unchanged.
P2	Unit (mobile)	QA-308	Given settings with <code>timeZone:"America/New_York"</code> at 2026-11-01 02:00 UTC, then the budgets screen opens on 2026-10.
P2	E2E (device)	QA-202 regression	Given a token issued 25 h ago, when the app is cold-started on mobile data 10 times, then Today loads every time and the login screen never appears.

9. Manual smoke test (≈15 minutes, real Android phone)

Production APK against a staging API. Steps marked $\triangle$ target findings in this report; a failure there confirms the finding.

#	Step	Expected
1	Cold-start while signed in, with the phone's date one day ahead (token older than 24 h). Repeat 5 times on mobile data.	Today loads from cache; no login screen (QA-202 regression check).
2	Quick-add “৳২০, সিন্ডার ১০”, then “৳২০।”, then “lunch 2x150”.	৳30 (low confidence, preview shown), ৳20, ৳300.
3	Settings > Numbers > Bangla, then open any amount keypad.	Keys and display show ০-৯; the saved amount is right.
4	Airplane mode: log “rickshaw 60 bkaash”, edit it to 70, reconnect.	One ৳70 expense on the server.
5	$\triangle$ Staging: make POST /tasks return 500 (for example by stopping the user DB from opening). Add a task, rename it, wait 3 minutes, restore the server, then tap Retry.	The task is saved with the new name (QA-301).
6	$\triangle$ Ask Tiki “set my food budget to 8000”; don't save. In Budgets, change Transport. Back in chat, tap Save.	Food changes and Transport keeps its new value (QA-302).
7	Ask Tiki “pay my internet bill”; don't save. Tap “Paid” on Today, then Save the draft.	“Already done, so nothing changed”; one expense.
8	Tap “Paid” on Today, then Undo in the snackbar.	The expense is gone and the bill is due again on its old date.
9	$\triangle$ Ask Tiki “turn off app lock”.	A confirmation, not an immediate change (QA-306).
10	Airplane mode: tap a widget quick-log, then open the app (still offline) and immediately swipe it away. Reopen and reconnect.	The widget expense reaches the server exactly once (QA-304).
11	Start a focus session; finish it after 1 minute.	A 1-minute focus entry in Time.
12	Turn on App lock, swipe the app away, reopen.	Fingerprint prompt before any content.
13	$\triangle$ Settings > Delete account: tap Export, share to Files, then delete. With <code>adb shell run-as</code> on a debug build, list <code>cache/</code> .	No <code>tick-taka-export-*.json</code> left (QA-307).
14	Staging: <code>curl -X PATCH .../settings -d '{"timeZone":"Dhaka"}'</code> .	400; pm2 shows no restarts.

Appendix A — Raw command output (trimmed)

Lint

```
$ bunx biome check .
Checked 523 files in 334ms. No fixes applied.
exit 0
```

Typecheck

```
@tick-taka/shared typecheck: Exited with code 0
@tick-taka/api typecheck: Exited with code 0
@tick-taka/mobile typecheck: Exited with code 0
```

Tests

```
@tick-taka/shared test: 247 pass 0 fail 519 expect() calls (13 files)
@tick-taka/mobile test: 233 pass 0 fail 683 expect() calls (43 files)
@tick-taka/api test:    209 pass 0 fail 759 expect() calls (31 files) [8.72s]
```

Coverage (selected lines)

```
shared All files 82.95 % funcs | 96.50 % lines
      src/quick-add.ts 96.15 | 90.00 | 459-460,588-597,614-647
mobile All files 93.47 % funcs | 93.79 % lines (pure modules only)
      src/lib/outbox-queue.ts 90.91 | 95.83 | 107-110,119,123-125
      src/lib/session-manager.ts 83.33 | 94.03 | 133-136
      src/lib/http.ts 46.15 | 81.25
      ../../packages/shared/src/dates.ts 45.16 | 0.00 <- QA-026 residual
api All files 88.18 % funcs | 94.49 % lines
      src/jobs/scheduler.ts 100.00 | 100.00 src/middleware/auth.ts 100.00 | 100.00
      src/modules/ai/assistant/actions.ts 100.00 | 96.00 | 83-89
      ../../packages/shared/src/dates.ts 90.32 | 5.99 <- QA-026 residual
```

Dependency audit

```
braces <=3.0.3 (high), node-forge <=1.4.0 (high), postcss-selector-parser, decode-uri-component,
esbuild (moderate) – 5 vulnerabilities (2 high, 3 moderate), all transitive; exit 1
(uuid now pinned to a patched 11.x by an override)
```

Android bundle

```
Android Bundled 24909ms apps/mobile/index.ts (2837 modules)
```

Appendix B — QA reproduction output

The scripts imported the project's own modules: `apps/api/test/helpers.ts` (in-memory SQLite, clock fixed at Sun 4 Oct 2026 10:00 Dhaka unless noted), `fake-ai.ts`, `money-helpers.ts`, the real mobile `OutboxQueue` and `undoPayRequests`, and the real drizzle migrations. They lived in `docs/audit/2026-10-07-r3/_qa_tmp/` and were deleted after the run. No source file was changed.

api-probe.ts (apps/api)

```
TZ: PATCH Dhaka -> 400 | PATCH "+06:00" -> 200 | GET /today -> 200
REFRESH: A after refresh 200 | B 200 | A 59s after B used 200 | A 61s after 401
CHECK: time entry create 201; PATCH endedAt before startedAt -> 400 "bad_request" | event
PATCH endsOn<startsOn -> 400
SYNC: limit=2 tasks 2 more=true | summary tasks=3 settings=0 rows=0 | limit=5000 -> 400
STALE set_budget draft: save 200 -> Food=800000, Fun=200000 (Fun was 300000 before Save)
(QA-302)
STUCK-CREATE: stuck POST /tasks | rejected PATCH tasks | stuck=["POST"] | after Retry: 200
title="Call bank" | queue size 0 (QA-301)
JOBS: one user's DB throws -> runHourlyJobs resolved
```

pay-undo.ts (apps/api + mobile recurring-pay.ts)

```
bill 201 2026-10-05
first previousDueAt 2026-10-05 | replay previousDueAt null | replay tx true
undo requests: DELETE transactions
after Undo: nextDueAt 2026-11-05 | expenses 0
(QA-303)
```

settings-probe.ts · auth-sweep.ts · mig-schema.ts

```
update_settings with draftMoney:true -> drafts 0, actions [{"summary":"Changed settings:
defaultCurrency, appLock"}]
settings now: defaultCurrency=USD appLock=false
(QA-306)
routes checked: 141; not answering 401 without a token: GET /health -> 200, GET / -> 200,
GET /privacy -> 200, GET /terms -> 200, POST /auth/google -> 400
0003 → 0005 schema diff: no column became NOT NULL
(by reading 0004: every new CHECK has a repair UPDATE before its table is rebuilt)
```

qa-probe.ts (packages/shared) — parser at df29d67 vs 7e2bfeb, inputs whose result changed

Input	df29d67	7e2bfeb
“চা ২০, সিঙ্গারা ১০”	expense ₳10, high, note “চা ২০, সিঙ্গারা”	expense ₳30, low, note “চা, সিঙ্গারা”
“চা ২০।”	task “চা ২০।”	expense ₳20, high, note “চা”
“lunch 2x150”	task “Lunch 2x150”	expense ₳300, high
“চা ২০ সিঙ্গারা ১০”	expense ₳10, high	expense ₳10, low (a stray amount lowers confidence)
“tea 20 + bun 15”	expense ₳15, high	expense ₳35, low, note “tea, bun”
“lunch 250.” · “lunch 250!” · “lunch 250।”	task	expense ₳250, high

Input	df29d67	7e2bfeb
"2 tea 40"	expense ₳40, high	expense ₳40, low
"tea 20 bKash, bun 15 cash"	expense ₳15 from Cash, high	expense ₳35 from bKash, low (the preview shows it)

Unchanged and correct: "lunch ১,২৫০" ₳1,250 · "রিকশা ৬০ টাকা" ₳60 · "১০০০ বেতন" income ₳1,000 · "+১০০০ salary" income ₳1,000 · "buy 4x4 tiles" task · "lunch -250" and "lunch 0" are tasks.

Appendix C — Requirement checklist used

From PRODUCT.md and the spec: log anything in under 5 s. Today answers “what now?” and “can I afford it?”. Safe to spend = flexible left ÷ days left including today, with fixed bills excluded. Amounts are integer minor units. Offline cache with queued writes sent in order, ids made on the phone, last-write-wins on updated_at. Asia/Dhaka by default for display, with local strings for habit dates and budget months. Streaks with 2 freezes a month. Reward, never guilt. Honest numbers (balances and hours reconcile). AI: rules first, a cost cap, graceful fallback, minimum data, an off switch, and never saving money without confirmation. App lock after 5 min. Receipts served only to authenticated requests. Login limited to 5 per 15 min. Bun listens on 127.0.0.1. Nightly VACUUM INTO backup keeping 14. JSON export. Local notifications with quiet hours 23:00–07:00. Bangla and English quick-add.

The round-1 fix contract adds: revocable sliding sessions with POST /auth/refresh, logout and account deletion. A 401 never clears the queue. A wipe happens only when a different user signs in. Signing out with pending writes asks first. Receipts load with a Bearer header only. The round-2 recommendations adopted since add: zone validation, per-user job isolation, a refresh grace window, CHECK → 400, stuck-write parking, money drafts for budgets and amount fields, and persisting the clock offset.

Appendix D — File inventory reviewed

Area	Files
Shared	packages/shared/src/{dates, digits, calculator, money, quick-add, defined}.ts, schemas/{common, settings}.ts
API core	apps/api/src/{index, env}.ts; middleware/{auth, error-handler}.ts; lib/{crud, log, user-time, validate}.ts; db/{client, sessions, user-registry, usage-totals}.ts; jobs/{scheduler, backup, offsite}.ts; drizzle/0004_constraints.sql
API modules	auth/{routes, session-token}, sync/routes, settings/service, budgets/{routes, service}, recurring/service, events/routes, time-entries/service, ai/usage, ai/assistant/{tools, actions, records, fields}
Mobile lib	outbox-policy, outbox-queue, outbox, connection, session-manager, session, auth, http, api, encrypted-storage, secure-storage, query-client, user-data, sync-changes, sync-paths, server-clock, phone-writes, optimistic-spend, user-time
Mobile features	app/_layout.tsx; components/ui/{sync-status, amount-keypad}; widget/{use-widget-sync, widget-cache, widget-pending, widget-quick-log, widget-task-handler}; assistant/{money-drafts, use-assistant, recover-turn, recovered-actions}; money/{recurring-pay, budget-edit-sheet}; today/pay-needs-rate; plan/{move-undo, use-move-task}; settings/{delete-account, delete-account-rules, use-export-data, confirm-sign-out}; focus/focus-screen; habits/habit-sheet; routines/routine-runner; notifications/use-notification-scheduler
Tests	apps/api/test/{helpers, assistant-helpers, money-helpers, jobs, sessions, time-zone, migrations, bulk-then-edit, assistant-money-drafts, logging}.test.ts; apps/mobile/test/{outbox-queue, session-manager}.test.ts; packages/shared/test/quick-add.test.ts; the file list of all three workspaces
Docs / raw	docs/AUDIT_PROMPT.md, README.md, docs/audit/2026-10-06-r2/QA_Report.html, docs/audit/2026-10-07-r3/_raw/*